PLAN DE RECUPERACIÓN ANTE INCIDENCIAS

Servidor DEBIAN 4Geeks Academy

Manuel Rosario Marín Fernández

19/03/2026

1. Introducción y Objetivos

Este Plan de Recuperación ante Incidencias (PRI) establece los procedimientos, responsabilidades y tiempos de respuesta para garantizar la continuidad de los servicios críticos del servidor LAMP de 4Geeks Academy ante cualquier incidente de seguridad, fallo técnico o desastre.

> Este plan se elabora como respuesta directa al incidente del 8 de octubre de 2024, en el que un atacante accedió al servidor como root desde 192.168.0.134, comprometiendo la totalidad del sistema.

1.1 Objetivos del plan

- Minimizar el tiempo de inactividad de los servicios críticos ante cualquier incidente.
- Establecer procedimientos claros y ordenados de detección, contención y recuperación.
- Garantizar la preservación de evidencias para análisis forense posterior.
- Asegurar la comunicación adecuada entre los equipos técnicos y la dirección.
- Prevenir la recurrencia de incidentes mediante medidas de endurecimiento post-recuperación.

1.2 Servicios críticos cubiertos

Servicio	Puerto	Criticidad	RTO	RPO
WordPress / Apache HTTP	80/tcp	ALTA	4 horas	24 horas
Base de datos MariaDB	3306/tcp	ALTA	4 horas	24 horas
SSH OpenSSH	22/tcp	MEDIA	8 horas	N/A
FTP vsftpd	21/tcp	BAJA	24 horas	N/A

RTO (Recovery Time Objective): tiempo máximo aceptable de inactividad del servicio.

RPO (Recovery Point Objective): antigüedad máxima aceptable de los datos recuperados.

2. Roles y Responsabilidades

Rol	Responsabilidad	Acción en incidente
Responsable de Seguridad	Coordina la respuesta al incidente, toma decisiones de contención	Lidera todas las fases del plan
Administrador del Sistema	Gestión técnica del servidor, aplicación de remediaciones	Ejecuta los procedimientos técnicos
Administrador de BD	Gestión y recuperación de bases de datos	Restaura backups de MariaDB
Responsable de Comunicación	Notificación interna y externa, gestión de stakeholders	Informa a dirección y usuarios
Dirección / Gerencia	Autorización de decisiones de alto impacto	Aprueba acciones críticas

3. Clasificación de Incidentes

Nivel	Descripción	Ejemplos	Tiempo de respuesta
P1 - CRÍTICO	Compromiso total del sistema o datos. Servicios caídos.	Acceso root no autorizado, ransomware, borrado de datos	< 1 hora
P2 - ALTO	Compromiso parcial. Servicio degradado o datos expuestos.	Acceso no autorizado a BD, web defacement, DoS	< 4 horas
P3 - MEDIO	Incidente contenido. Sin impacto en producción inmediato.	Escaneo activo, intentos de fuerza bruta detectados	< 8 horas
P4 - BAJO	Anomalía menor. Sin impacto operativo.	Acceso fallido aislado, advertencia de log	< 24 horas

El incidente del 8 de octubre de 2024 fue clasificado como P1 - CRÍTICO: acceso root completo al sistema con borrado posterior de logs de autenticación.

4. Procedimientos de Respuesta y Recuperación

El plan se estructura en 6 fases secuenciales. Cada fase tiene un responsable, pasos concretos y tiempo objetivo.

FASE 1: DETECCIÓN Y NOTIFICACIÓN ⏱ Tiempo objetivo: 0-1 hora
1. Identificar la alerta inicial: monitorización de logs, IDS/IPS, o reporte de usuario.
2. Registrar fecha, hora exacta y naturaleza del incidente en el registro de incidentes.
3. Clasificar el incidente según la tabla de la sección 3 (P1-P4).
4. Notificar inmediatamente al Responsable de Seguridad.
5. Activar el equipo de respuesta según la criticidad del incidente.
6. Notificar a dirección si el incidente es P1 o P2.
7. Abrir un canal de comunicación seguro (no usar los sistemas comprometidos).

FASE 2: CONTENCIÓN ⏱ Tiempo objetivo: 1-2 horas
1. AISLAMIENTO: desconectar el servidor de la red si el compromiso está activo (ifdown enp0s3).
2. PRESERVACIÓN: tomar snapshot de la máquina virtual ANTES de cualquier cambio.
3. Identificar el vector de ataque para evitar re-infección durante la recuperación.
4. Bloquear la IP atacante en el firewall: iptables -A INPUT -s <IP_ATACANTE> -j DROP.
5. Deshabilitar servicios comprometidos temporalmente: systemctl stop ssh vsftpd apache2.
6. Cambiar todas las contraseñas de acceso al sistema desde un equipo no comprometido.
7. Documentar todas las acciones tomadas con timestamps para el análisis forense.

FASE 3: ANÁLISIS FORENSE ⏱ Tiempo objetivo: 2-6 horas
1. Recopilar evidencias: logs de sistema, auth.log, journalctl, access.log de Apache.
2. Ejecutar script de análisis forense para captura del estado del sistema.
3. Identificar archivos modificados en las últimas 24-72 horas: find / -mtime -3.
4. Revisar historial de comandos de todos los usuarios: cat /home/*/.bash_history.
5. Analizar procesos activos y conexiones de red: ps aux, ss -tulpn.
6. Verificar integridad de archivos críticos: wp-config.php, sshd_config, vsftpd.conf.
7. Identificar y documentar el vector de entrada, el alcance del compromiso y los datos afectados.
8. Elaborar informe forense preliminar.

FASE 4: ERRADICACIÓN ⏱ Tiempo objetivo: 6-12 horas
1. Eliminar cualquier backdoor, webshell o archivo malicioso encontrado durante el análisis.

2. Limpiar entradas sospechosas en crontabs: crontab -l y /etc/crontab.
3. Eliminar usuarios no autorizados creados por el atacante: userdel -r <usuario>.
4. Restaurar archivos de configuración críticos desde backup o valores seguros conocidos.
5. Actualizar el sistema operativo y todos los paquetes: apt-get update && apt-get upgrade -y.
6. Actualizar WordPress y todos sus plugins a la última versión estable.
7. Eliminar software innecesario que amplíe la superficie de ataque.
8. Verificar que no existen puertas traseras en servicios activos.

FASE 5: RECUPERACIÓN Y ENDURECIMIENTO ⏱ Tiempo objetivo: 12-24 horas

1. Restaurar datos desde el último backup limpio verificado.
2. Verificar integridad del backup antes de restaurar: comprobar checksums.
3. Reconectar el servidor a la red de forma controlada.
4. Aplicar TODAS las remediaciones de seguridad documentadas en el informe de incidente.
5. Verificar que todos los servicios funcionan correctamente tras la restauración.
6. Realizar un escaneo de vulnerabilidades post-recuperación (Nmap + Nikto).
7. Confirmar que los vectores de ataque identificados están correctamente cerrados.
8. Monitorizar el sistema durante 48-72 horas con especial atención a anomalías.

FASE 6: REVISIÓN POST-INCIDENTE ⏱ Tiempo objetivo: 24-72 horas

1. Elaborar el informe final del incidente con toda la documentación recopilada.
2. Realizar reunión de lecciones aprendidas con todos los involucrados.
3. Actualizar este Plan de Recuperación con las mejoras identificadas.
4. Implementar medidas preventivas adicionales para evitar recurrencia.
5. Actualizar el inventario de activos y la documentación de seguridad.
6. Comunicar el cierre del incidente a todos los stakeholders.
7. Programar auditoría de seguridad en los próximos 30 días.

5. Política de Copias de Seguridad

5.1 Estrategia de backup

Componente	Frecuencia	Retención	Ubicación	Método
Base de datos MariaDB	Diaria (02:00)	30 días	Servidor externo + local	mysqldump
Archivos WordPress /var/www/html	Semanal (domingo 03:00)	4 semanas	Servidor externo	rsync / tar.gz
Configuraciones del sistema	Tras cada cambio	Indefinida	Repositorio Git privado	git commit
Snapshot VM completa	Semanal	2 semanas	Almacenamiento NAS	VirtualBox snapshot

5.2 Comandos de backup

Backup de base de datos:

```
mysqldump -u root -p --all-databases > backup_$(date +%Y%m%d).sql
gzip backup_$(date +%Y%m%d).sql
```

Backup de archivos WordPress:

```
tar -czf wordpress_backup_$(date +%Y%m%d).tar.gz /var/www/html/
```

Backup de configuraciones críticas:

```
cp /etc/ssh/sshd_config /backup/configs/sshd_config_$(date +%Y%m%d)
cp /etc/vsftpd.conf /backup/configs/vsftpd_$(date +%Y%m%d)
cp /var/www/html/wp-config.php /backup/configs/wp-config_$(date +%Y%m%d)
```

5.3 Verificación de backups

Los backups deben verificarse mensualmente mediante el siguiente procedimiento:

1. Restaurar el backup en entorno de prueba aislado.
2. Verificar integridad de la base de datos: mysqlcheck -u root -p --all-databases.
3. Comprobar accesibilidad del sitio WordPress en el entorno de prueba.
4. Registrar resultado de la verificación en el registro de backups.

6. Procedimiento de Restauración Detallado

6.1 Restauración de base de datos

```
# 1. Acceder al servidor como administrador
sudo mysql -u root -p

# 2. Dentro de MySQL, restaurar el backup
SOURCE /ruta/al/backup.sql;
EXIT;

# 3. Verificar integridad
mysqlcheck -u root -p --all-databases
```

6.2 Restauración de WordPress

```
# 1. Detener Apache
sudo systemctl stop apache2

# 2. Hacer backup del estado actual (por si acaso)
sudo tar -czf /tmp/wordpress_before_restore.tar.gz /var/www/html/

# 3. Restaurar desde backup
sudo tar -xzf wordpress_backup_YYYYMMDD.tar.gz -C /

# 4. Restaurar permisos correctos
sudo chown -R www-data:www-data /var/www/html/
sudo find /var/www/html/ -type f -exec chmod 644 {} \;
sudo find /var/www/html/ -type d -exec chmod 755 {} \;
sudo chmod 640 /var/www/html/wp-config.php

# 5. Reiniciar Apache
sudo systemctl start apache2
sudo systemctl status apache2
```

6.3 Verificación post-restauración

Verificación	Comando	Resultado esperado
Apache activo	systemctl status apache2	active (running)
MariaDB activo	systemctl status mariadb	active (running)
SSH activo	systemctl status ssh	active (running)
WordPress accesible	curl -s -o /dev/null -w "%{http_code}" http://localhost	200 OK
xmlrpc bloqueado	curl -s -o /dev/null -w "%{http_code}" http://localhost/xmlrpc.php	403 Forbidden
SSH root bloqueado	grep PermitRootLogin /etc/ssh/sshd_config	PermitRootLogin no

Verificación	Comando	Resultado esperado
FTP anónimo bloqueado	grep anonymous_enable /etc/vsftpd.conf	anonymous_enable=NO

7. Plan de Comunicación

7.1 Comunicación interna

Evento	A quién notificar	Canal	Plazo
Detección de incidente P1/P2	Responsable de Seguridad + Dirección	Teléfono / Mensajería segura	Inmediato (< 30 min)
Confirmación del compromiso	Todo el equipo técnico + Dirección	Reunión de emergencia	< 1 hora
Contención completada	Dirección + Stakeholders internos	Email seguro	< 2 horas
Recuperación completada	Toda la organización	Email + comunicado interno	< 24 horas
Informe final	Dirección + equipo técnico	Documento formal	< 72 horas

7.2 Comunicación externa

En caso de que el incidente afecte a datos de usuarios o clientes, aplicar el siguiente protocolo:

- Notificar a los usuarios afectados en un plazo máximo de 72 horas desde la detección.
- Comunicar a la Agencia Española de Protección de Datos (AEPD) si hay datos personales comprometidos.
- Preparar un comunicado público con información factual, sin especular sobre el alcance.
- Evitar revelar detalles técnicos del ataque que puedan facilitar nuevos ataques.

8. Medidas Preventivas para Evitar Recurrencia

8.1 Medidas implementadas tras el incidente

Medida	Estado	Verificación
SSH PermitRootLogin deshabilitado	Implementado	grep PermitRootLogin /etc/ssh/sshd_config → no
Autenticación SSH por contraseña deshabilitada	Implementado	grep PasswordAuthentication → no
FTP anónimo deshabilitado	Implementado	grep anonymous_enable /etc/vsftpd.conf → NO
FTP con SSL habilitado	Implementado	grep ssl_enable /etc/vsftpd.conf → YES
Contraseña BD WordPress robusta	Implementado	Contraseña de 20+ caracteres con símbolos

Medida	Estado	Verificación
wp-config.php con permisos restrictivos	Implementado	chmod 640, propietario www-data
xmlrpc.php bloqueado (403)	Implementado	curl http://.../xmlrpc.php → 403
info.php eliminado	Implementado	ls /var/www/html/info.php → No such file
Directory listing deshabilitado	Implementado	curl /wp-content/uploads/ → 403
Headers de seguridad HTTP (X-Frame, X-Content, X-XSS)	Implementado	curl -I localhost | grep X-Frame → DENY
ETag deshabilitado (FileETag None)	Implementado	curl -I localhost | grep ETag → (sin resultado)
robots.txt eliminado	Implementado	ls /var/www/html/robots.txt → No such file

8.2 Medidas adicionales recomendadas

Medida	Prioridad	Plazo
Instalar y configurar Fail2Ban para SSH y FTP	ALTA	Inmediato
Configurar UFW - firewall con reglas restrictivas	ALTA	Inmediato
Implementar autenticación SSH por clave pública	ALTA	Corto plazo
Configurar headers de seguridad HTTP en Apache	MEDIA	Corto plazo
Deshabilitar directory listing en Apache	MEDIA	Corto plazo
Habilitar logging persistente (rsyslog)	ALTA	Inmediato
Implementar sistema de monitorización (Wazuh/OSSEC)	MEDIA	Medio plazo
Auditorías de seguridad periódicas (trimestrales)	MEDIA	Planificado

9. Pruebas y Mantenimiento del Plan

9.1 Calendario de pruebas

Tipo de prueba	Frecuencia	Responsable	Descripción
Verificación de backups	Mensual	Administrador de sistema	Restaurar backup en entorno de prueba y verificar integridad
Simulacro de incidente P3	Trimestral	Responsable de Seguridad	Simulación de detección y respuesta a incidente de severidad media
Escaneo de vulnerabilidades	Mensual	Administrador de sistema	Nmap + Nikto sobre el servidor en producción
Revisión del plan	Semestral	Todo el equipo	Actualizar procedimientos y contactos del plan
Simulacro completo P1	Anual	Toda la organización	Simulación completa de incidente crítico con todos los procedimientos

9.2 Criterios de actualización del plan

Este plan debe actualizarse obligatoriamente en los siguientes casos:

- Después de cualquier incidente de seguridad real.
- Cuando se produzcan cambios significativos en la infraestructura.
- Cuando se incorporen nuevos servicios o se eliminen existentes.
- Cuando cambien los responsables de los roles definidos en la sección 2.
- Semestralmente como revisión de mantenimiento ordinaria.

10. Registro de Incidentes

Campo	Incidente Oct 2024
ID de incidente	INC-2024-001
Fecha de detección	18 de marzo de 2026 (análisis forense)
Fecha del incidente	8 de octubre de 2024 - 17:40:59 EDT
Clasificación	P1 - CRÍTICO
Vector de entrada	SSH con login root habilitado y contraseña débil
IP atacante	192.168.0.134
Alcance	Acceso root completo - todos los servicios comprometidos
Datos afectados	Base de datos WordPress, archivos del servidor, logs eliminados
Tiempo de detección	Aproximadamente 5 meses (análisis forense posterior)
Tiempo de remediación	1 día (19 de marzo de 2026)

Campo	Incidente Oct 2024
Estado	CERRADO - Remediado

11. Conclusión

Este Plan de Recuperación ante Incidencias proporciona un marco estructurado para responder, contener y recuperar los servicios críticos del servidor LAMP de 4Geeks Academy ante cualquier incidente de seguridad.

La experiencia del incidente de octubre de 2024 ha demostrado la importancia crítica de contar con un plan documentado, backups verificados y medidas preventivas activas. La implementación de las medidas descritas en este plan, junto con las remediaciones ya aplicadas, sitúa al servidor en un estado de seguridad significativamente superior al existente en el momento del incidente.

Recordatorio: Este plan solo es efectivo si se practica. Se recomienda realizar el primer simulacro de incidente en los próximos 30 días para validar los procedimientos aquí descritos.